

Auftragsverarbeitungsvertrag (AVV) / Data Processing Agreement (DPA)

*Scandora — Managed AI, Cloud-Verlaufssynchronisation, Opt-in-Suchindex, serverseitiger DATEV-Export, GoBD-Aufzeichnungen & geräteübergreifendes Importregister · Art. 28 DSGVO
/ GDPR*

Fassung / Version: 2026-09-08 (Rev. 6)

Entwurf — externe anwaltliche Prüfung ausstehend. / Draft — external counsel review pending.

Dieser AVV ist ein interner Entwurf, intern gegen die tatsächlichen Datenflüsse von Scandora geprüft. Er wurde noch nicht von externen Rechtsanwälten geprüft und kann sich ändern, bevor er zum Abschluss einer verbindlichen Vereinbarung verwendet wird. / This DPA is an internal draft, reviewed in-house against Scandora's actual data flows. It has not yet been reviewed by external legal counsel and may change before it is used to conclude a binding agreement.

Vertragsparteien / Contracting Parties

Verantwortlicher (Auftraggeber) / Controller (Customer)

Firma / Company: _____

Anschrift / Address: _____

Vertreten durch / Represented by: _____

E-Mail / Email: _____

Auftragsverarbeiter / Processor

Farhad Sanaei seresht (Einzelunternehmen, Geschäftsbezeichnung „Scandora“)

Burgunderweg 19G, 22453 Hamburg, Deutschland

E-Mail: privacy@scandora.eu

Deutsche Fassung (maßgeblich)

Auftragsverarbeitungsvertrag (AVV) gemäß Art. 28 DSGVO

Dieser Vertrag konkretisiert die datenschutzrechtlichen Pflichten der Parteien für die Verarbeitung personenbezogener Daten, die Scandora als Auftragsverarbeiter im Auftrag des Verantwortlichen durchführt. Er gilt ergänzend zu den Nutzungsbedingungen und der Datenschutzerklärung von Scandora.

Hinweis: Die Kontodaten des Verantwortlichen (E-Mail-Adresse, Name, Abonnement- und Abrechnungsdatensatz) sowie die E-Mail-Korrespondenz mit Scandora liegen außerhalb dieses AVV; insoweit ist Scandora Verantwortlicher aufgrund seines eigenen Vertrags mit dem Kunden. Der Verlaufseintrag unterfällt dagegen vollständig diesem Vertrag — der extrahierte Dokumenttext, das Vorschaubild und die Metadaten des Eintrags: Der Verantwortliche entscheidet, welche Dokumente gescannt und warum sie aufbewahrt werden; Scandora speichert den Eintrag daher als Auftragsverarbeiter und nutzt ihn für keine eigenen Zwecke. Abschnitt 8 der Datenschutzerklärung von Scandora führt Verlaufs-Metadaten unter der Verantwortlichenrolle von Scandora auf; das beschreibt die Nutzung ohne AVV, bei der die nutzende Person betroffene Person und nicht Verantwortlicher ist.

1. Gegenstand und Dauer

Gegenstand ist die Verarbeitung von Dokumentinhalten des Verantwortlichen auf sechs Wegen: (a) verwaltete KI (Managed AI) — Weiterleitung von Dokumentinhalten an einen KI-Modellanbieter zur Erzeugung von Analyseergebnissen; verwaltete KI ist der einzige KI-Weg dieser Version, eine Mitbring-Funktion für eigene API-Schlüssel ist nicht Bestandteil dieser Version (Abschnitt 6 der AGB), sodass jede KI-Anfrage zu Dokumenten des Verantwortlichen über Scandoras eigenes KI-Gateway läuft und diesem Vertrag unterfällt; der Opt-in-Suchindex und der Dokument-Chat laufen auf den nachstehend beschriebenen Wegen und unterfallen ihm ebenfalls; (b) Cloud-Verlaufssynchronisation — Speicherung des Verlaufseintrags jedes abgeschlossenen Scans auf dem eigenen Server von Scandora in Falkenstein, Deutschland, damit der Verlauf auf allen Geräten des Verantwortlichen verfügbar ist; (c) KI-Dokumenten-Suchindex (Opt-in) — Speicherung des aus den Dokumenten extrahierten Textes und der KI-Beschreibung samt der daraus berechneten Such-Embeddings im EU-Index von Scandora, soweit der Verantwortliche ihn einschaltet; ein Dokument mit bis zu 1.200 Zeichen wird vollständig indexiert, ein längeres in überlappende Passagen zerlegt, von denen bis zu die ersten 100 indexiert werden, jede Passage trägt im Kopf Titel, Art und Datum des Dokuments, und zum Dokument werden zusätzlich dessen Art, das Dokumentdatum, die gesetzten Labels, die Kennung des zugrunde liegenden Verlaufseintrags und die Profilkennung gespeichert; Originaldateien werden dort nicht gespeichert; (d) serverseitiger DATEV-Export (in Vorbereitung; für die Tarife Business und Enterprise vorgesehen und noch nicht freigeschaltet, sodass auf diesem Weg derzeit keine Daten fließen) — Übermittlung der exportierten Buchungssätze (je Buchung Datum, Bruttobetrag, Soll-/Haben-Kennzeichen, Konto und Gegenkonto, DATEV-BU-Schlüssel, Rechnungsnummer, Buchungstext, Erkennungs-Konfidenzwert,

Dokumentdateiname) samt Exportkopf (Berater- und Mandantennummer, Kontenrahmen, Beginn des Wirtschaftsjahres, exportierter Zeitraum, Name der exportierenden Person) und der dazugehörigen Dokumentbilder an den eigenen Server von Scandora in Falkenstein, Zusammenstellung der DATEV-EXTF-ZIP-Datei und Rückgabe an den Verantwortlichen, ohne Speicherung von Buchungssätzen oder Bildern; (e) GoBD-Erfassungs- und Änderungsaufzeichnungen — solange die für den Verantwortlichen handelnde Person angemeldet ist, schreibt jede Erfassung, jede Metadatenänderung, jeder Export und jede Löschung einen Datensatz auf denselben Server: einen Erfassungsnachweis (SHA-256-Prüfsumme der erfassten Datei, Erfassungsquelle, Gerätebeschreibung, Nutzer- und Profilkennung, Server-Zeitstempel) und einen Änderungsprotokolleintrag (Dokumentkennung, Ereignisart — Erfassung, Bearbeitung, Export oder Löschung —, Nutzerkennung, handelndes Profil, Server-Zeitstempel, bei einem Export das gewählte Exportziel und, bei einer Bearbeitung, der alte und der neue Wert jedes geänderten Metadatenfeldes); keiner der beiden Datensätze enthält ein Seitenbild oder den Dokumenttext, und beide werden in jedem Tarif geschrieben, ohne dass dies abwählbar wäre; (f) geräteübergreifendes Importregister — importiert der Verantwortliche ein Dokument aus einem verbundenen Cloud-Speicher (Google Drive, Dropbox, OneDrive, Nextcloud, Trello) oder über die Dateiauswahl des Geräts, hält Scandora diesen Import zentral fest, damit ein zweites Gerät dieselbe Datei nicht erneut importiert; dieser Datensatz liegt als einziger nicht auf dem eigenen Server von Scandora, sondern in Google Firestore in der Region europe-west3 (Frankfurt), und enthält die Quellidentität (Anbieter, Kennung des Quellkontos, Dateikennung und Versionsmarke des Anbieters oder, bei einer über die Dateiauswahl gewählten Datei, einen SHA-256-Fingerabdruck ihres Inhalts), Konto- und Profilkennung, den Importstatus, Status und Speicherreferenz je Ziel sowie eine kurzlebige Gerätereservierung — kein Seitenbild und keinen Dokumenttext, während die Speicherreferenz die Datei-URL des Ziels oder der Dateipfad der erzeugten PDF ist und daher den Dateinamen des Dokuments enthalten kann; er wird in jedem Tarif bei jedem Import geschrieben, ein erneuter Import derselben Datei entfernt ihn, und die Kontolöschung löscht sämtliche Einträge des Kontos. Nimmt Scandora später einen weiteren Weg hinzu, auf dem Dokumentinhalte des Verantwortlichen in dessen Auftrag verarbeitet werden, informiert Scandora ihn vor dem Wirksamwerden in Textform und passt die Abschnitte 3 und 6 entsprechend an; der Verantwortliche kann vor dem Wirksamwerden widersprechen. Widerspricht er, wird der neue Weg für sein Konto nicht freigeschaltet und dieser Vertrag gilt für die oben genannten Wege unverändert fort; kann Scandora die Leistung ohne diesen Weg nicht erbringen, teilt Scandora dies auf den Widerspruch hin mit, und der Verantwortliche kann diesen Vertrag und den zugrunde liegenden Vertrag zu dem Zeitpunkt kündigen, zu dem die Erweiterung wirksam geworden wäre. Widerspricht er nicht, gilt dieser Vertrag ab diesem Zeitpunkt auch für den neuen Weg. Die Verarbeitung dauert an, solange der Verantwortliche Scandora nutzt, und endet mit Beendigung des zugrunde liegenden Vertrags.

Speicherdauer: Verlaufseinträge werden für die Dauer des Kontos aufbewahrt; ein gelöschter Eintrag wird mit der Löschung entfernt, bei Kontolöschung werden sämtliche Einträge des Kontos mitgelöscht, spätestens innerhalb von 30 Tagen. Beim Opt-in-Index wirken zwei getrennte Bedienelemente unterschiedlich: Das Ausschalten des Schalters für die serverseitige Suche pausiert die Indexierung — neue Dokumente werden nicht mehr

indexiert, bereits gespeicherter Text und bereits gespeicherte Embeddings bleiben erhalten. „Einstellungen → Einwilligung widerrufen und Server-Index löschen“ löscht sie; die App meldet den Erfolg erst, wenn der Server die Indexeinträge tatsächlich gelöscht hat. Das Löschen eines Verlaufseintrags entfernt sie nicht von sich aus. Gelöscht werden sie außerdem, wenn der Tarif den Index nicht mehr gewährt, innerhalb von 30 Tagen nach Kontolöschung sowie zum Ablauf der Aufbewahrungsfrist: Sieht der Tarif keine Aufbewahrungsfrist nach Kündigung vor, nach 30 Tagen ohne Kontoaktivität; sieht er eine vor, nach Ablauf dieser Frist nach Ende des Abonnements. Der Importregistereintrag wird für die Dauer des Kontos aufbewahrt; ein erneuter Import derselben Datei löscht ihn, und die Kontolöschung löscht sämtliche Einträge des Kontos.

Die GoBD-Erfassungs- und Änderungsaufzeichnungen werden weder beim Löschen des zugehörigen Verlaufseintrags noch bei Kontolöschung entfernt. Was eine Kontolöschung sehr wohl bewirkt, ist die Ersetzung der Kennungen darin: Nutzer- und Profilkennung werden durch eine Ersatzkennung ersetzt, und die geänderten Metadatenwerte sowie die Namen exportierter Dateien werden mit dem Konto entfernt; Prüfsumme, Zeitstempel und Hash-Verkettung bleiben erhalten, sodass die Aufzeichnungen ohne die Kennungen fortbestehen, mit denen sie geschrieben wurden. Das Ergebnis gibt Scandora nicht als anonyme Daten aus: Der Verkettungs-Fingerabdruck jedes Eintrags wurde vor dieser Ersetzung berechnet, und die Prüfsumme des Erfassungsnachweises passt weiterhin zum Dokument selbst; wer dieses Dokument oder die ersetzten Kennungen besitzt, kann einen Eintrag daher weiterhin einer Person zuordnen. Kein deutsches Gesetz verpflichtet Scandora zur Aufbewahrung dieser Aufzeichnungen. Die Aufzeichnungs- und Unveränderbarkeitspflichten nach den GoBD (§ 146 Abs. 4, § 147 AO, § 239 Abs. 3 HGB) treffen den Verantwortlichen bzw. sein Unternehmen, nicht Scandora, und § 257 HGB bindet Kaufleute, was Scandora — betrieben als nicht im Handelsregister eingetragenes Kleingewerbe — nicht ist. Scandora stützt sich daher nicht auf Art. 28 Abs. 3 lit. g DSGVO, der dem Auftragsverarbeiter eine Aufbewahrung über das Vertragsende hinaus nur dort erlaubt, wo das Unionsrecht oder das Recht eines Mitgliedstaats die Speicherung vorschreibt. Scandora bewahrt diese Aufzeichnungen zum eigenen Nachweiszweck auf und ist für diese Aufbewahrung Verantwortlicher (Art. 6 Abs. 1 lit. f DSGVO): Ein mit Scandora erfasstes Dokument soll so lange überprüfbar bleiben, wie der Verantwortliche es vorlegen müsste. Sie werden in jedem Tarif geschrieben und lassen sich nicht abschalten; Scandora stellt diese Aufbewahrung daher nicht als Weisung des Verantwortlichen dar. Scandora bewahrt beide Aufzeichnungen zehn Jahre auf — die Frist, die das deutsche Recht für die eigenen Bücher und Aufzeichnungen eines Gewerbetreibenden vorsieht (§ 147 Abs. 1 Nr. 1, Abs. 3 AO) —, gerechnet ab dem Schluss des Kalenderjahres, in dem die Aufzeichnung entstanden ist (§ 147 Abs. 4 AO), und löscht sie nach deren Ablauf. Diese Frist ist eine von Scandora selbst gesetzte Obergrenze und keine Scandora betreffende Speicherpflicht; Abschnitt 11 der Datenschutzerklärung sagt dasselbe. Die Lösch- oder Rückgabepflicht aus Abschnitt 5 erfasst diese beiden Aufzeichnungen während dieser Frist nicht. Eine Einschränkung, offen gesagt: Heute entfernt nichts diese Datensätze nach Fristablauf — das Änderungsprotokoll ist auf Datenbankebene reine Anfügung, seine Einträge lassen sich überhaupt nicht löschen, und noch keine Routine löscht die Erfassungsnachweise nach Fristablauf; diesen Löschschritt zu bauen, steht auf der Liste von Scandora. Endet die Aufbewahrungspflicht des Verantwortlichen früher, teilt er dies in

Textform mit; Scandora nutzt die Aufzeichnungen dann ausschließlich zu diesem Nachweiszweck (Art. 18 DSGVO) und vermerkt einen Widerspruch (Art. 21 DSGVO). Eine frühere Löschung sagt Scandora nicht zu, weil sie technisch nicht ausführbar ist. Die Datenbank weist jede Löschung eines Änderungsprotokolleintrags zurück und jede Änderung daran mit einer einzigen Ausnahme: einer Änderung, die die Kontrollöschungs-Kennzeichnung von Scandora trägt, die Verkettungswerte und die Zeitstempel unangetastet lässt und den Eintrag als geschwärzt kennzeichnet — diese Kennzeichnung setzt allein die Kontrollöschungs-Routine, und ein so gekennzeichnete Eintrag wird nicht mehr gegen seinen eigenen Fingerabdruck geprüft. Prüfsumme und Zeitstempel des Erfassungsnachweises sind einmalig beschreibbar; ein einzelner Eintrag lässt sich daher weder berichtigen noch löschen (siehe Abschnitt 9).

2. Art und Zweck der Verarbeitung

Auf dem Managed-AI-Pfad: transiente Verarbeitung von Dokumentbildern, extrahiertem Text und Prompts zur Erzeugung von Analyseergebnissen (z. B. Titel, Labels, extrahierte Felder, Antworten); diese Inhalte werden von Scandora nach Erzeugung des Ergebnisses nicht aufbewahrt. Auf dem Weg der Cloud-Verlaufssynchronisation und im Opt-in-Suchindex: dauerhafte Speicherung der in Abschnitt 3 genannten Daten zum Zweck der geräteübergreifenden Verlaufssynchronisation bzw. der Beantwortung von Suchen und Fragen im Dokument-Chat. Auf dem Weg des serverseitigen DATEV-Exports (in Vorbereitung, siehe Abschnitt 1): vorübergehende Verarbeitung der Buchungssätze und der dazugehörigen Dokumentbilder zur Erstellung der DATEV-EXTF-ZIP-Datei ohne Speicherung. Auf dem Weg der GoBD-Aufzeichnungen: dauerhafte Speicherung des Erfassungsnachweises und des Änderungsprotokolleintrags zum Nachweis, dass eine erfasste Datei unverändert ist und jede spätere Änderung an ihren Metadaten nachvollziehbar bleibt. Auf dem Weg des Importregisters: Speicherung eines Registereintrags je Import in Google Firestore (Frankfurt), damit dieselbe Quelldatei nicht auf mehreren Geräten doppelt importiert wird. Der Modellanbieter (Google) kann ausgewählte Prompts bei Bedarf temporär zur Missbrauchsüberwachung aufbewahren, potenziell bis zu 90 Tage; diese Daten werden nicht zum Trainieren oder Fine-Tunen von Google-Modellen verwendet.

3. Art der personenbezogenen Daten

Dokumentbilder und der daraus extrahierte Text sowie Prompts und Fragen zu einem Dokument; der auf dem eigenen Server von Scandora gespeicherte Verlaufseintrag mit dem vollständigen aus dem Dokument extrahierten Text (OCR-Text, gespeichert bis zu einer Obergrenze von 400.000 Zeichen), einem kleinen Base64-Vorschaubild der ersten Seite und den Metadaten des Eintrags (Titel, Erstellungsdatum, Seitenzahl, Dateigröße, Labels, gewählte Exportziele sowie von der KI extrahierte Felder wie Betrag, Rechnungsnummer und Rechnungsdatum); sowie im Opt-in-Index der vollständige aus dem Dokument extrahierte Text und dessen KI-Beschreibung, für die Indexierung in Passagen zerlegt (ein Dokument mit bis zu 1.200 Zeichen vollständig, ein längeres in überlappende Passagen, von denen bis zu die ersten 100 indexiert werden), jede Passage mit Titel, Art und Datum des Dokuments im Kopf, die daraus berechneten Such-Embeddings sowie die zum Dokument gespeicherte Art, das Dokumentdatum, die Labels, die Kennung des zugrunde

liegenden Verlaufseintrags und die Profilkennung — keine Originaldateien; die Daten eines DATEV-Exports (vorübergehend; der Export ist in Vorbereitung und noch nicht freigeschaltet): die Buchungssätze (je Buchung Datum, Bruttobetrag, Soll-/Haben-Kennzeichen, Konto und Gegenkonto, DATEV-BU-Schlüssel, Rechnungsnummer, Buchungstext, Erkennungs-Konfidenzwert, Dokumentdateiname), der Exportkopf (Beraternummer, Mandantenummer, Kontenrahmen, Beginn des Wirtschaftsjahres, exportierter Zeitraum, Name der exportierenden Person) und die dazugehörigen Dokumentbilder; sowie die GoBD-Erfassungs- und Änderungsaufzeichnungen: je Erfassung eine SHA-256-Prüfsumme der erfassten Datei, die Erfassungsquelle (Kamera, Netzwerkscanner oder Datei-Upload), eine Gerätebeschreibung, die Nutzer- und Profilkennung und ein Server-Zeitstempel; je Dokumentereignis die Dokumentkennung, die Ereignisart (Erfassung, Bearbeitung, Export, Löschung), die Nutzerkennung, das handelnde Profil, ein Server-Zeitstempel, bei einem Export das gewählte Exportziel und, bei einer Bearbeitung, der alte und der neue Wert jedes geänderten Metadatenfeldes (Titel, Labels, Bruttobetrag, Rechnungsnummer, Rechnungsdatum) — kein Seitenbild und kein Dokumenttext; sowie der Importregistereintrag: Quellanbieter, Kennung des Quellkontos, Dateikennung und Versionsmarke des Anbieters oder — bei einer über die Dateiauswahl gewählten Datei — ein SHA-256-Fingerabdruck ihres Inhalts, Konto- und Profilkennung, Importstatus, Status und Speicherreferenz je Ziel sowie eine kurzlebige Gerätereservierung, ohne Seitenbild und ohne Dokumenttext; die Speicherreferenz ist die Datei-URL des Ziels oder der Dateipfad der erzeugten PDF und kann daher den Dateinamen des Dokuments enthalten. Diese Daten können besondere Kategorien personenbezogener Daten (Art. 9 DSGVO) enthalten, soweit der Verantwortliche solche Dokumente übermittelt.

4. Kategorien betroffener Personen

Vom Verantwortlichen bestimmte Personen, deren Daten in den verarbeiteten Dokumenten enthalten sind (z. B. Mandanten, Kunden, Mitarbeitende).

5. Pflichten des Auftragsverarbeiters

Verarbeitung nur auf dokumentierte Weisung des Verantwortlichen, es sei denn, Scandora ist nach dem Unionsrecht oder dem Recht eines Mitgliedstaats, dem Scandora unterliegt, zu einer anderen Verarbeitung verpflichtet; in diesem Fall teilt Scandora dem Verantwortlichen diese rechtliche Anforderung vor der Verarbeitung mit, sofern das betreffende Recht diese Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet (Art. 28 Abs. 3 lit. a DSGVO); unverzügliche Information des Verantwortlichen, wenn eine Weisung nach Auffassung von Scandora gegen die DSGVO oder andere Datenschutzbestimmungen der Union oder der Mitgliedstaaten verstößt (Art. 28 Abs. 3 Unterabs. 2 DSGVO); Vertraulichkeitsverpflichtung der zur Verarbeitung befugten Personen; Umsetzung der technischen und organisatorischen Maßnahmen (Abschnitt 8); Unterstützung bei Betroffenenrechten und bei den Pflichten nach Art. 32–36 DSGVO; Löschung oder Rückgabe der Daten nach Wahl des Verantwortlichen bei Vertragsende (Art. 28 Abs. 3 lit. g DSGVO); die GoBD-Erfassungs- und Änderungsaufzeichnungen nach Abschnitt 1 fallen nicht unter diese Pflicht: Scandora bewahrt sie als Verantwortlicher zum eigenen Nachweiszweck für die dort genannte, von Scandora selbst gesetzte Zehnjahresfrist auf — keine Scandora treffende Speicherpflicht — und das Änderungsprotokoll lässt sich

überdies überhaupt nicht Eintrag für Eintrag löschen; Bereitstellung der zur Nachweisführung erforderlichen Informationen sowie Duldung und Unterstützung von Überprüfungen, einschließlich Inspektionen, durch den Verantwortlichen oder einen von ihm beauftragten Prüfer (Art. 28 Abs. 3 lit. h DSGVO).

6. Unterauftragsverarbeiter

Der Verantwortliche genehmigt den Einsatz der unten gelisteten Unterauftragsverarbeiter für die in Abschnitt 1 beschriebene Verarbeitung. Für die Verarbeitung, die Scandora als Auftragsverarbeiter durchführt, ist die Anlage 1 dieses Vertrags maßgeblich. Abschnitt 7 der Datenschutzerklärung von Scandora (<https://scandora.eu/privacy.html>) verfolgt einen anderen Zweck: Er listet sämtliche Empfänger personenbezogener Daten auf, einschließlich der Anbieter, die Scandora als Verantwortlicher für eigene Zwecke einsetzt; soweit beide denselben Anbieter beschreiben, gilt für die auftragsverarbeitende Seite dieser Vertrag. Scandora informiert über beabsichtigte Änderungen und räumt ein Widerspruchsrecht ein. Scandora erlegt jedem Unterauftragsverarbeiter dieselben Datenschutzpflichten auf, die in diesem Vertrag festgelegt sind (Art. 28 Abs. 4 DSGVO).

7. Drittlandübermittlung

Soweit Unterauftragsverarbeiter Daten außerhalb der EU/EWR (z. B. USA) verarbeiten, erfolgt dies auf Grundlage der EU-Standardvertragsklauseln und/oder einer Zertifizierung unter dem EU-US Data Privacy Framework. Die nach diesem Vertrag gespeicherten Daten verbleiben auf den eigenen Servern von Scandora in Falkenstein, Deutschland, mit einer Ausnahme: Das geräteübergreifende Importregister wird in Google Cloud Firestore in der Region europe-west3 (Frankfurt) gespeichert. Beide Orte liegen in Deutschland, sodass keiner der beiden Speicher eine Drittlandübermittlung ist; für die übrige Google-Cloud-Verarbeitung um diesen Speicher herum gelten die EU-Standardvertragsklauseln und/oder die DPF-Zertifizierung von Google. Die KI-Generierung erfolgt in Deutschland, wenn der Frankfurter Regionaldienst (Vertex AI europe-west3) genutzt wird.

8. Technische und organisatorische Maßnahmen (TOM)

Verschlüsselung in der Übertragung (TLS) auf jeder Verbindung zwischen App, den Servern von Scandora und den Unterauftragsverarbeitern; Verschlüsselung hinterlegter Integrations- und KI-Zugangsdaten pro Nutzer (AES-256-GCM), während für die übrigen nach diesem Vertrag gespeicherten Daten keine Verschlüsselung im Ruhezustand als Maßnahme angeführt wird; rollenbasierte Zugriffskontrolle und Protokollierung; Pseudonymisierung der Nutzerkennung (Firebase-UID); transiente Verarbeitung auf dem Managed-AI-Pfad ohne Speicherung über die Anfrage hinaus; Trennung gespeicherter Einträge je Nutzer und Profil, lesbar nur mit dem authentifizierten Token dieses Nutzers; Hosting der Gateway- und OAuth-Komponenten sowie sämtlicher nach diesem Vertrag gespeicherter Daten auf dem eigenen Server von Scandora in Falkenstein, Deutschland, mit zwei in Deutschland verbleibenden Ausnahmen: Der KI-Modellaufruf geht in die Google-Region europe-west3 (Frankfurt), und das Importregister wird in Google Cloud Firestore in derselben Region gespeichert; regelmäßige Updates, Wiederherstellbarkeit und

Belastbarkeit der Systeme; Verfahren zur regelmäßigen Überprüfung der Wirksamkeit der Maßnahmen.

9. Rechte des Verantwortlichen / der betroffenen Personen

Der Verantwortliche bleibt Herr der Daten. Betroffene Personen haben die Rechte aus Art. 15–22 DSGVO (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch). Scandora unterstützt den Verantwortlichen bei deren Erfüllung. Für die GoBD-Erfassungs- und Änderungsaufzeichnungen nach Abschnitt 1 ist diese Unterstützung durch deren reine Anfügung begrenzt: Auskunft (Art. 15), Einschränkung der weiteren Verwendung (Art. 18), Herausgabe der Einträge (Art. 20) und der Vermerk eines Widerspruchs (Art. 21) sind möglich; die Berichtigung (Art. 16) oder Löschung (Art. 17) eines einzelnen Eintrags während der in Abschnitt 1 genannten, von Scandora selbst gesetzten Aufbewahrungsfrist ist es nicht; wie dort offen dargelegt, entfernt sie heute auch nach Fristablauf nichts. Die Kontolöschung ersetzt die Kennungen in jedem Eintrag des Kontos, die Einträge bleiben aber personenbezogene Daten.

10. Schlussbestimmungen

Maßgeblich ist die deutsche Fassung. Es gilt deutsches Recht. Sollten einzelne Bestimmungen unwirksam sein, bleibt der übrige Vertrag wirksam.

Anlage 1 — Unterauftragsverarbeiter / Annex 1 — Sub-Processors

Anbieter / Provider	Zweck / Purpose	Region
Scandora AI Gateway (selbst betrieben / self-operated)	Managed AI — Routing & Metering; Embeddings für den Opt-in-Index / routing & metering of AI requests; embeddings for the opt-in index	EU
Hetzner Online GmbH	Hosting des eigenen EU-Servers: Verlaufsspeicher, Opt-in-Index, Zusammenstellung des DATEV-Exports (in Vorbereitung) sowie GoBD-Erfassungs- und Änderungsaufzeichnungen / hosting of Scandora's own EU server: history store, opt-in index, DATEV export assembly (coming soon) and the GoBD capture and change records	Deutschland (Falkenstein) / Germany (Falkenstein)
Google (Gemini API)	KI-Modellanbieter (Analyse und Embeddings) / AI model provider (analysis and embeddings)	Deutschland (Frankfurt) — Vertex AI europe-west3 für Generierung und Embeddings; übrige Google-Cloud-Verarbeitung (u. a. Kontrollebene/Support) auf Grundlage der EU-Standardvertragsklauseln / des DPF / Germany (Frankfurt) — Vertex AI europe-west3 for generation and embeddings; remaining Google Cloud processing (incl. control plane/support) on the basis of the EU Standard Contractual Clauses / DPF
Google (Firebase / Cloud Firestore)	Speicherung des geräteübergreifenden Importregisters (keine Dokumentinhalte) / storage of the cross-device import register (no document content)	Deutschland (Frankfurt) — Firestore-Region europe-west3; übrige Google-Cloud-Verarbeitung (u. a. Kontrollebene/Support) auf Grundlage der EU-Standardvertragsklauseln / des DPF / Germany (Frankfurt) — Firestore region europe-west3; remaining Google Cloud processing (incl.

		control plane/support) on the basis of the EU Standard Contractual Clauses / DPF
--	--	--

English version (courtesy translation)

Data Processing Agreement (DPA) pursuant to Art. 28 GDPR

This agreement sets out the data-protection obligations of the parties for the processing of personal data that Scandora performs as a processor on behalf of the controller. It supplements Scandora's Terms of Service and Privacy Policy.

Note: the controller's own account data (email address, name, subscription and billing record) and email correspondence with Scandora sit outside this DPA; for those Scandora is the controller under its own contract with the customer. The history record, by contrast, is covered by this agreement in full — the extracted document text, the preview thumbnail and the record's metadata: the controller decides which documents are scanned and why they are kept, so Scandora stores the record as processor and uses it for no purpose of its own. Section 8 of Scandora's Privacy Policy lists history metadata under Scandora's controller role; that describes use without a DPA, where the user is a data subject rather than a controller.

1. Subject and Duration

The subject is the processing of the controller's document content on six paths: (a) managed AI — routing document content to an AI model provider to produce analysis results; managed AI is the only AI path in this version, a bring-your-own-API-key option is not part of this version (section 6 of the Terms), so every AI request about the controller's documents runs through Scandora's own AI gateway and is covered by this agreement; the opt-in search index and document chat run on the paths described below and are covered by it as well; (b) cloud history sync — storing each completed scan's history record on Scandora's own server in Falkenstein, Germany, so that the history is available on all of the controller's devices; (c) AI document search index (opt-in) — storing the text extracted from the documents and their AI descriptions, together with the search embeddings computed from that text, in Scandora's EU index, where the controller switches it on; a document of up to 1,200 characters is indexed whole, a longer one is split into overlapping passages of which up to the first 100 are indexed, every passage carries a header with the document's title, type and date, and the document's type, document date, labels, the identifier of the source history record and the profile identifier are stored with it; the original files are not stored there; (d) server-side DATEV export (coming soon; designed for the Business and Enterprise plans and not yet switched on, so no data travels this path yet) — sending the exported booking rows (per booking the date, gross amount, debit/credit marker, account and contra account, DATEV BU key, invoice number, booking text, recognition confidence and document file name) together with the export header (Berater and Mandant number, chart of accounts, fiscal-year start, exported date range, the name set as the exporting user) and the document images attached to those bookings to Scandora's own server in Falkenstein, assembling the DATEV EXTF ZIP there and returning it to the controller, without storing the rows or the images; (e) GoBD capture and change records — while the person acting for the controller is signed in, every capture, metadata

edit, export and deletion writes a record to the same server: a capture record (SHA-256 checksum of the captured file, capture source, device description, user and profile identifier, server timestamp) and a change-log entry (document identifier, event type — capture, edit, export or delete —, user identifier, acting profile, server timestamp, for an export the chosen destination and, for an edit, the old and the new value of each metadata field that changed); neither record holds a page image or the document text, and both are written on every plan, with no way to switch them off; (f) cross-device import register — where the controller imports a document from a connected cloud storage (Google Drive, Dropbox, OneDrive, Nextcloud, Trello) or from the device's file picker, Scandora records that import centrally so a second device cannot import the same file again; this record is the only one not held on Scandora's own server but in Google Firestore in the europe-west3 (Frankfurt) region, and it carries the source identity (provider, an identifier of the source account, the provider's file identifier and version marker or, for a file picked on the device, a SHA-256 fingerprint of that file's content), the account and profile identifier, the import status, the status and storage reference of each destination and a short-lived device lease — no page image and no document text, while the storage reference is the destination's file URL or the generated PDF's file path and can therefore contain the document's file name; it is written on every plan on every import, importing the same file again removes it, and account deletion erases every entry of the account. If Scandora later adds a further path on which the controller's document content is processed on the controller's behalf, Scandora informs the controller in text form before that extension takes effect and updates sections 3 and 6 accordingly; the controller may object before it takes effect. If the controller objects, the new path is not activated for that account and this agreement continues unchanged for the paths listed above; where Scandora cannot provide the service without that path, Scandora says so in answer to the objection and the controller may terminate this agreement and the underlying contract with effect from the date the extension would have taken effect. If the controller does not object, this agreement covers the new path from that date. Processing lasts for as long as the controller uses Scandora and ends when the underlying contract ends.

Retention: history records are kept for the life of the account; a record the controller deletes is erased with that deletion, and on account deletion every record of the account is erased with it, at the latest within 30 days. For the opt-in index two separate controls do different things: turning the server-side search switch off pauses indexing — no new documents are indexed, and the text and embeddings already stored remain. “Settings → Withdraw consent and delete server index” erases them; the app reports success only once the server has actually erased the index entries. Deleting a history record does not remove them on its own. They are also erased when the plan stops granting the index, within 30 days of account deletion, and on the retention deadline: where the plan states no retention period after cancellation, after 30 days without account activity; where it states one, that period after the subscription ends. The import-register entry is kept for the life of the account; importing the same file again deletes it, and account deletion erases every entry of the account.

The GoBD capture and change records are not removed when the corresponding history record is deleted, nor on account deletion. What an account deletion does do is replace the

identifiers in them: the user and profile identifiers are replaced by a stand-in value, and the edited metadata values and the exported file names are removed with the account, while the checksum, the timestamps and the hash chain stay, so the records survive without the identifiers they were written with. Scandora does not present the result as anonymous data: each entry's chain fingerprint was computed before that replacement, and the capture record's checksum still matches the document itself, so anyone holding that document or the replaced identifiers can still tie an entry to a person. No German law requires Scandora to store these records. The GoBD record-keeping and unalterability duties (§ 146(4), § 147 AO, § 239(3) HGB) bind the controller or its business, not Scandora, and § 257 HGB binds merchants, which Scandora — run as an unregistered sole proprietorship (Kleingewerbe) — is not. Scandora therefore does not rely on Art. 28(3)(g) GDPR, which lets a processor keep data past the end of the contract only where Union or Member State law requires that storage. Scandora keeps these records for its own evidence purpose and is the controller for that retention (Art. 6(1)(f) GDPR): a document captured with Scandora should stay verifiable for as long as the controller may have to produce it. They are written on every plan and cannot be switched off; Scandora therefore does not present that retention as an instruction given by the controller. Scandora keeps both records for ten years, the period German law sets for a trader's own books and records (§ 147(1) No. 1, (3) AO), counted from the end of the calendar year in which the record was made (§ 147(4) AO), and deletes them once that period has expired. That period is a cap Scandora sets itself, not a storage duty imposed on it; section 11 of the privacy policy says the same. The delete-or-return duty in section 5 does not reach these two records while that period runs. One limitation, stated plainly: today nothing removes these rows by age — the change log is append-only at database level, so its entries cannot be deleted at all, and no routine yet deletes the capture records when the period expires; building that deletion step is on Scandora's list. Where the controller's own retention duty ends earlier, the controller says so in text form; Scandora then uses the records for that evidence purpose only (Art. 18 GDPR) and notes an objection (Art. 21 GDPR). Scandora does not promise an earlier erasure, because it cannot be carried out. The database rejects every deletion of a change-log entry, and every change to one except a change that carries Scandora's account-deletion marker, leaves the chain values and the timestamps untouched and marks the entry as redacted — only the account-deletion routine sets that marker, and a marked entry is no longer checked against its own fingerprint. The capture record's checksum and timestamp are write-once, so a single entry can be neither rectified nor erased (see section 9).

2. Nature and Purpose of Processing

On the managed AI path: transient processing of document images, extracted text and prompts to produce analysis results (e.g. titles, labels, extracted fields, answers); Scandora does not retain that content once the result has been produced. On the cloud history sync path and in the opt-in index: storage of the data listed in section 3 for the purpose of syncing the history across devices and of answering searches and document-chat questions. On the server-side DATEV export path (coming soon, see section 1): transient processing of the booking rows and the attached document images to build the DATEV EXTF ZIP, without storage. On the GoBD records path: storage of the capture record and the change-log entry as evidence that a captured file is unaltered and that every later change to its metadata

stays traceable. On the import-register path: storage of one register entry per import in Google Firestore (Frankfurt), so that the same source file is not imported twice across the controller's devices. The model provider (Google) may temporarily retain selected prompts for abuse monitoring when applicable, potentially for up to 90 days; this data is not used to train or fine-tune Google models.

3. Type of Personal Data

Document images and the text extracted from them, plus prompts and questions about a document; the history record stored on Scandora's own server, carrying the full text extracted from the document (OCR text, stored up to a 400,000-character cap), a small base64 preview thumbnail of the first page and the record's metadata (title, creation date, page count, file size, labels, chosen export destinations and the fields extracted by the AI such as amount, invoice number and invoice date); and, in the opt-in index, the full text extracted from the document and its AI description, split into passages for indexing (a document of up to 1,200 characters whole, a longer one in overlapping passages of which up to the first 100 are indexed), every passage carrying a header with the document's title, type and date, the search embeddings computed from those passages and, stored with the document, its type, its document date, the labels, the identifier of the source history record and the profile identifier — not the original files; the DATEV export payload (transient; the export is coming soon and not yet switched on): the booking rows (per booking the date, gross amount, debit/credit marker, account and contra account, DATEV BU key, invoice number, booking text, recognition confidence and document file name), the export header (Berater number, Mandant number, chart of accounts, fiscal-year start, exported date range, the name set as the exporting user) and the document images attached to those bookings; and the GoBD capture and change records: per capture a SHA-256 checksum of the captured file, the capture source (camera, network scanner or file upload), a device description, the user and profile identifier and a server timestamp; per document event the document identifier, the event type (capture, edit, export, delete), the user identifier, the acting profile, a server timestamp, for an export the chosen destination and, for an edit, the old and the new value of each metadata field that changed (title, labels, gross amount, invoice number, invoice date) — no page image and no document text; and the import-register entry: the source provider, an identifier of the source account, the provider's file identifier and version marker or — for a file picked on the device — a SHA-256 fingerprint of that file's content, the account and profile identifier, the import status, the status and storage reference of each destination and a short-lived device lease, with no page image and no document text; the storage reference is the destination's file URL or the generated PDF's file path and can therefore contain the document's file name. This data may contain special categories of personal data (Art. 9 GDPR) where the controller submits such documents.

4. Categories of Data Subjects

Persons determined by the controller whose data is contained in the processed documents (e.g. clients, customers, employees).

5. Obligations of the Processor

Processing only on the controller's documented instructions, unless Scandora is required to process otherwise by Union or Member State law to which Scandora is subject; in that case Scandora informs the controller of that legal requirement before processing, unless that law prohibits such information on important grounds of public interest (Art. 28(3)(a) GDPR); immediate information to the controller if, in Scandora's opinion, an instruction infringes the GDPR or other data-protection provisions of the Union or of a Member State (Art. 28(3), final subparagraph GDPR); confidentiality of authorised personnel; implementation of the technical and organisational measures (section 8); assistance with data-subject rights and with the obligations under Art. 32–36 GDPR; deletion or return of data at the controller's choice on termination (Art. 28(3)(g) GDPR); the GoBD capture and change records under section 1 are outside that duty: Scandora keeps them as controller for its own evidence purpose, for the ten-year period stated there — a cap Scandora sets itself, not a storage duty imposed on it — and the change log cannot be deleted entry by entry at all; provision of the information needed to demonstrate compliance, and allowing for and contributing to audits, including inspections, conducted by the controller or an auditor mandated by the controller (Art. 28(3)(h) GDPR).

6. Sub-Processors

The controller authorises the sub-processors listed below for the processing described in section 1. For the processing Scandora performs as processor, Annex 1 to this agreement is the authoritative list. Section 7 of Scandora's Privacy Policy (<https://scandora.eu/privacy.html>) serves a different purpose: it lists every recipient of personal data, including the providers Scandora uses as controller for its own purposes; where the two describe the same provider, this agreement governs the processor-side processing. Scandora informs of intended changes and grants a right to object. Scandora imposes on every sub-processor the same data-protection obligations as are set out in this agreement (Art. 28(4) GDPR).

7. International Transfers

Where sub-processors process data outside the EU/EEA (e.g. the USA), this is based on the EU Standard Contractual Clauses and/or certification under the EU-US Data Privacy Framework. The data stored under this agreement stays on Scandora's own servers in Falkenstein, Germany, with one exception: the cross-device import register is stored in Google Cloud Firestore in the europe-west3 (Frankfurt) region. Both locations are in Germany, so neither store is a third-country transfer; for the remaining Google Cloud processing around that store the EU Standard Contractual Clauses and/or Google's DPF certification apply. AI generation is processed in Germany when the Frankfurt regional service (Vertex AI europe-west3) is used.

8. Technical and Organisational Measures (TOMs)

Encryption in transit (TLS) on every connection between the app, Scandora's servers and the sub-processors; per-user encryption of stored integration and AI credentials (AES-256-GCM), while for the remaining data stored under this agreement no encryption at rest is claimed as a measure; role-based access control and logging; pseudonymisation of the user

identifier (Firebase UID); transient processing on the managed AI path with no storage beyond the request; separation of stored records per user and per profile, readable only with that user's authenticated token; hosting of the gateway and OAuth components and of all data stored under this agreement on Scandora's own server in Falkenstein, Germany, with two exceptions that both stay in Germany: the AI model call goes to Google's europe-west3 region (Frankfurt), and the import register is stored in Google Cloud Firestore in the same region; regular updates, recoverability and resilience of systems; a process for regularly testing the effectiveness of the measures.

9. Rights of the Controller / Data Subjects

The controller remains in control of the data. Data subjects have the rights under Art. 15–22 GDPR (access, rectification, erasure, restriction, portability, objection). Scandora assists the controller in fulfilling them. For the GoBD capture and change records under section 1 that assistance is limited by their append-only design: access (Art. 15), restriction of further use (Art. 18), export of the entries (Art. 20) and noting an objection (Art. 21) are possible; rectification (Art. 16) or erasure (Art. 17) of a single entry while the self-set retention period stated in section 1 runs is not; as stated plainly there, today nothing removes them once that period expires either. Deleting the account replaces the identifiers in every one of its entries, but the entries stay personal data.

10. Final Provisions

The German version prevails. German law applies. If individual provisions are invalid, the remainder of the agreement remains in force.

Unterzeichnung / Signatures

Ort, Datum / Place, Date: _____

Verantwortlicher / Controller: _____

(Unterschrift / Signature, Name in Druckbuchstaben / printed name)

Auftragsverarbeiter / Processor (Scandora): _____

(Unterschrift / Signature)